

DigiT — The Admin Layer

Control plane, tenant vs platform admin, and the security model · v1.0

An **admin layer** is the control plane of the application — the screens, permissions and tools used to *run* DigiT, as opposed to the parts customers use to do their work. This document goes deep on what that means, distinguishes the two admin layers DigiT needs, details the architecture and the security model, and ends with a glossary defining every technical term used.

1 The core idea — control plane vs data plane

In any serious system the **data plane** is where the actual work flows (customers using workspaces, the CRM, the AI feed), and the **control plane** is the machinery that governs that work — configuring it, monitoring it, turning things on and off. The admin layer *is* the control plane. Think back office versus shop floor. Keeping the two separate — mentally and physically — is what makes a platform operable and secure.

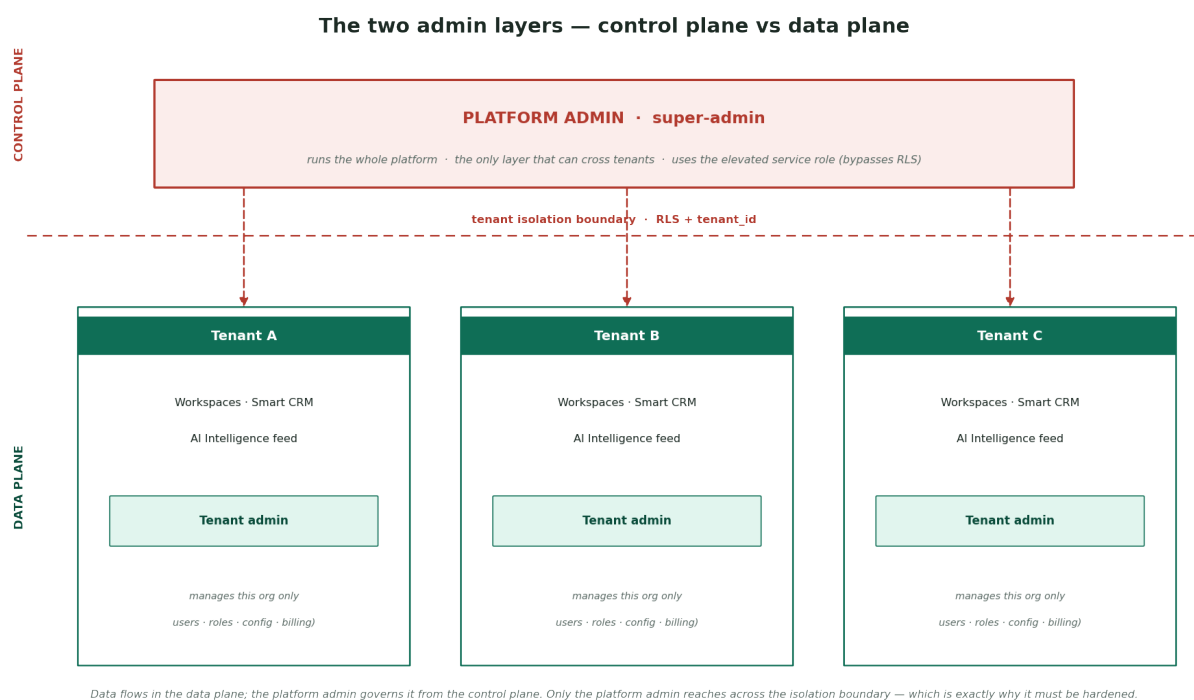


Figure 1 — The platform admin (control plane) sits above the tenant isolation boundary and is the only layer that can cross tenants; each tenant admin lives inside its own tenant (data plane).

2 The two admin layers

They live at different levels of the multi-tenancy model — and must never be conflated.

- **Tenant admin (your customer's)** — operates *inside* one tenant, bounded by the tenant isolation boundary — the wall enforced by row-level security (RLS) and the `tenant_id` tag on every row. It can only ever touch its own org's data.
- **Platform admin (yours / super-admin)** — operates *above* all tenants, in the control plane. It sits **outside** the isolation boundary — the one place in the whole system that can legitimately cross tenants. That is what makes it powerful and dangerous in equal measure.

3 Tenant admin — components

Scoped to one org; much of this you have already designed.

- **Organisation & user management** — invite / remove members; user provisioning & deprovisioning; optionally via SCIM (the standard for syncing users from a company's directory).

- **Roles & access (RBAC)** — assign members to view / edit / admin — your #3 engine and the “Roles & access” step in the Configure wizard.
 - **Workspace configuration** — the Configure wizard and its settings-hub mode (owner / admin-only reconfiguration).
 - **AI guardrails** — scope, allowance and human-in-the-loop confidence for AI Intelligence.
 - **Billing & audit views** — their plan and invoices; a read view of their own audit log.
 - **Identity setup** — SSO / SAML / OIDC for their workforce.
-

4 Platform admin — components

The control plane you operate. This is the part not yet documented.

- **Tenant lifecycle management** — provisioning (create a tenant), suspension, deprovisioning, and soft delete (recoverable) vs hard delete (physically purged). The onboarding verification queue — approving company-registration checks — lives here.
 - **Impersonation (support access)** — “sign in as” / assume-identity to see what a customer sees and debug. The most abuse-prone capability: it must be consented, time-boxed, fully audited, and must never expose the user's credentials.
 - **Observability** — the umbrella term, built on the three pillars — metrics, logs, traces. Around it: monitoring, alerting, health checks, APM, and reliability targets SLI / SLO / SLA, plus uptime and MTTR.
 - **Billing operations** — dunning (chasing failed payments), proration, entitlements (what a plan unlocks), metering (counting AI usage), and the metrics MRR / ARR and churn.
 - **Feature management** — feature flags / toggles, kill switches, canary releases and progressive rollouts (ship to 5% first), and entitlement gating per tier.
 - **Data governance** — handling DSARs (data-subject access requests), PII, data residency and retention policies under DPDP / GDPR.
 - **Trust & safety / incident response** — the abuse queue, the security queue, on-call rotations and runbooks.
-

5 Where it lives — the architecture

The platform admin is usually a **separate application** (e.g. `admin.digit-ai.org`), not just elevated routes inside the customer app — a smaller blast radius and a separate deploy. The dangerous part is technical: to cross tenants it must **bypass RLS** using an elevated database role. In Supabase terms that is the `service_role` key (which ignores row-level security) versus the `anon` key the normal app uses. Any code holding `service_role` is effectively **God-mode**, so it is isolated behind an **admin API / internal API** and an API gateway, and never shipped to the browser.

6 The security model

Because the platform admin crosses isolation, it is hardened far beyond the normal app — in layers (defense in depth).

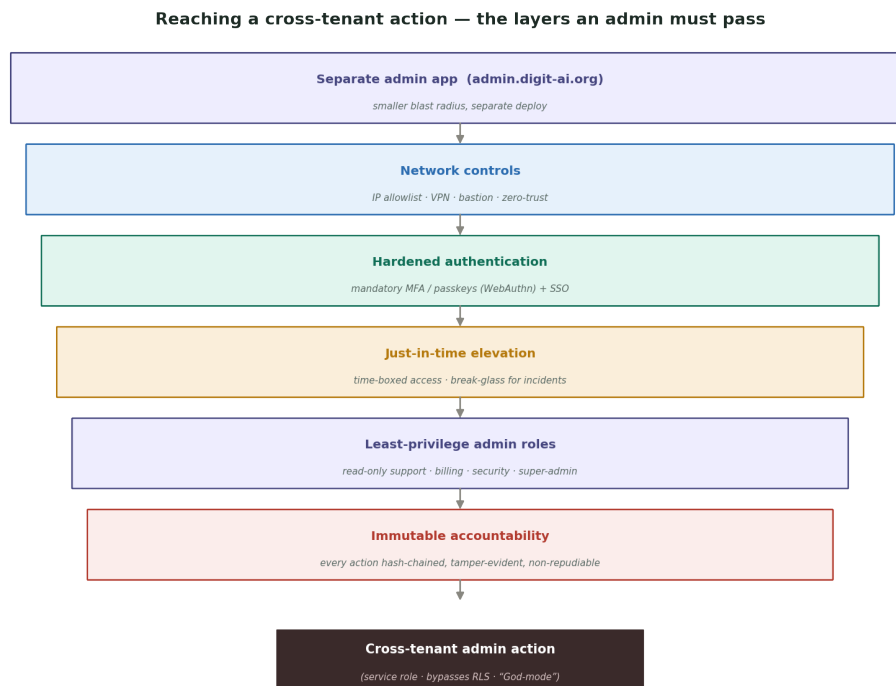


Figure 2 — Every cross-tenant admin action must pass through all of these layers.

- **Principle of least privilege (PoLP)** — every admin gets the minimum access needed; admin itself is tiered.
- **Separation of duties (SoD)** — no single person can do everything unchecked (e.g. issuing vs approving refunds).
- **Just-in-time (JIT) access** — you don't hold super-admin all day — you elevate for a time-boxed window, then it drops.
- **Break-glass** — a deliberately alarmed emergency-access path for incidents, logged loudly.
- **Hardened authentication** — mandatory MFA / passkeys (WebAuthn), SSO, plus network controls: IP allowlist, VPN, bastion host, zero-trust.
- **Immutable accountability** — every admin action written to an append-only, hash-chained, tamper-evident audit log (WORM storage, often streamed to a SIEM), giving non-repudiation.

7 Tiered admin roles

Least privilege in practice — few people hold the last one.

- **Read-only support** — can view and impersonate, cannot change anything.
- **Billing admin** — subscriptions, refunds, plan changes.
- **Security admin** — audit, access control, incident response.
- **Super-admin / root** — full control, held by very few.

8 How this maps to DigiT

What you already have, and where the gap is.

You have already built much of the **tenant** admin: RBAC (#3), the “Roles & access” step in the Configure wizard, owner / admin-only reconfiguration, audit logging (#10) and Monitoring & Reliability (#21). Your **founder dashboard** is the embryo of the *platform* admin — you looking across everything. The real gap is a proper, hardened **platform-admin layer** with the tenant-lifecycle, impersonation and cross-tenant security controls described above.

Glossary — every technical term

Control plane — the part of a system that governs and configures how it runs (the admin layer).

Data plane — the part where the actual user workload flows (the customer-facing app).

Multi-tenancy — one deployment serving many isolated customers; the opposite of single-tenancy (a separate instance per customer).

Tenant / Tenancy — a single customer organisation within a multi-tenant system, and the model that keeps them apart.

Tenant isolation — the guarantee that one tenant can never access another's data.

Row-level security (RLS) — a database feature that filters every query by a rule (here, `tenant_id`) so rows from other tenants are invisible.

`tenant_id` — the column tagging every row with its owning tenant; the basis of isolation.

`service_role` / **anon key** — Supabase keys: `anon` obeys RLS (used by the app); `service_role` bypasses RLS (used only by trusted server code).

RLS bypass — running queries with an elevated role that ignores row-level security — necessary for cross-tenant admin, and dangerous.

Noisy neighbor — one tenant's heavy usage degrading others on shared infrastructure.

Provisioning / Deprovisioning — creating (and tearing down) a tenant or user account and its resources.

Tenant lifecycle — the full arc: provision → active → suspend → deprovision.

Soft delete / Hard delete — marking data deleted but recoverable, vs physically and irreversibly purging it.

Impersonation — an admin viewing the app as a specific user (sign-in-as / assume-identity) to debug; must be consented and audited.

RBAC / ABAC / PBAC — role- / attribute- / policy-based access control — three models for deciding who can do what.

Principle of least privilege (PoLP) — granting the minimum access needed for a task, nothing more.

Separation of duties (SoD) — splitting a sensitive action across people so no one can complete it alone.

Privilege escalation — gaining access beyond what was granted — a class of attack the admin layer must resist.

Super-admin / root / God-mode — the highest, unrestricted level of access; held by very few and heavily audited.

Service account — a non-human identity used by code / automation, with its own scoped permissions.

MFA / 2FA — multi- / two-factor authentication — requiring more than a password to sign in.

Passkey / WebAuthn / FIDO2 — phishing-resistant, hardware-backed credentials that replace passwords.

SSO / SAML / OIDC / OAuth — single sign-on and the protocols behind it — logging in via an identity provider (Google, Microsoft, etc.).

SCIM — a standard for automatically syncing users / groups from a company's directory into an app.

Just-in-time (JIT) access — granting elevated access only for a short, time-boxed window, then revoking it.

Break-glass — a pre-defined, heavily-alarmed emergency access path used only during incidents.

IP allowlist — restricting access to a known set of network addresses.

Bastion host / jump box — a hardened gateway server you must go through to reach sensitive systems.

VPN / Zero-trust — a private network tunnel; and the model of never trusting a request by network location alone, always verifying.

Audit log / Audit trail — the recorded history of who did what, and when.

Append-only / Immutable — records can be added but never edited or deleted.

Hash-chain / Tamper-evident — each log entry cryptographically linked to the last, so any alteration is detectable.

WORM — write-once-read-many storage — data cannot be changed after being written.

Non-repudiation — the property that an actor cannot deny having performed a recorded action.

SIEM — security information & event management — a system that aggregates and analyses logs for threats.

Feature flag / toggle — a switch to turn a feature on or off without redeploying.

Kill switch — a flag to instantly disable a feature or the whole system in an emergency.

Canary release / Progressive rollout — releasing a change to a small percentage of users first, then widening.

Entitlement — what a given plan or account is allowed to access or use.

Observability — the ability to understand a system's internal state from its outputs.

Metrics / Logs / Traces — the “three pillars” of observability — numbers over time, event records, and request paths across services.

APM — application performance monitoring — tracking latency, errors and throughput.

Monitoring / Alerting / Health check — watching the system, notifying humans when thresholds break, and endpoints that report if a service is alive.

SLI / SLO / SLA — service-level indicator (a measured metric), objective (your internal target), and agreement (the contractual promise).

Uptime / MTTR — the percentage of time a service is available; and mean time to recovery after an incident.

Dunning — the automated process of retrying and chasing failed payments.

Proration — charging or crediting for partial billing periods when plans change mid-cycle.

MRR / ARR / Churn — monthly / annual recurring revenue; and the rate at which customers cancel.

Metering / Usage records — measuring consumption (e.g. AI actions) to bill for it.

DSAR — data-subject access request — a person's legal request to see, export or delete their data.

PII — personally identifiable information.

Data residency — the requirement that data be stored in a specific country or region.

Retention policy — rules for how long data is kept before deletion.

GDPR / DPDP — the EU and Indian data-protection laws governing personal data.

Blast radius — how much can be affected if something is compromised or fails — minimised by isolation.

Incident response / On-call / Runbook — the process, the rota of responders, and the step-by-step guides for handling failures.

Admin API / Internal API / API gateway — the private interfaces the admin layer uses, and the controlled entry point in front of them.